The ACE-OAuth framework described in section 13.3.2 allows access tokens to be issued in CBOR Web Token (CWT, https://datatracker.ietf.org/doc/html/rfc8392) format and include an encrypted symmetric key that can be used to secure communications between the device and an API. In this case the access token effectively acts like a certificate but is issued as required by a central authorization server rather than being deployed to the device at manufacturing time.

13.1.3 Authenticating at the transport layer

If there is a direct connection between a device and the API it's accessing, then you can use authentication mechanisms provided by the transport layer security protocol. For example, the pre-shared key (PSK) cipher suites for TLS described in chapter 12 provide mutual authentication of both the client and the server. Client certificate authentication can be used by more capable devices just as you did in chapter 11 for service clients. In this section, we'll look at identifying devices using PSK authentication.

During the handshake, the client provides a PSK identity to the server in the ClientKeyExchange message. The API can use this PSK ID to locate the correct PSK for that client. The server can look up the device profile for that device using the PSK ID at the same time that it loads the PSK, as shown in figure 13.2. Once the handshake has completed, the API is assured of the device identity by the mutual authentication that PSK cipher suites achieve.